

What's wrong with WebSocket APIs? Unveiling vulnerabilities in WebSocket APIs.

What's wrong with WebSocket APIs? Unveiling vulnerabilities in WebSocket APIs. - @speakerdeck, Mikhail Egorov, Speaker Deck.

- Published: 2019-10-25
- Original: <<https://speakerdeck.com/0ang3el/whats-wrong-with-websocket-apis-unveiling-vulnerabilities-in-websocket-apis>>
- Preserved from: <https://speakerdeck.com/0ang3el/whats-wrong-with-websocket-apis-unveiling-vulnerabilities-in-websocket-apis> (live) on 2026-08-06
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

What's wrong with WebSocket APIs? Unveiling vulnerabilities in WebSocket APIs. - Speaker Deck

What's wrong with WebSocket APIs? Unveiling vulnerabilities in WebSocket APIs.

Slides from Hacktivity 2019 conference - <https://hacktivity.com/index.php/presentations/>.

[[image: Avatar for Mikhail Egorov](#)]

Mikhail Egorov

October 25, 2019

More Decks by Mikhail Egorov

[See All by Mikhail Egorov](#)

[

A Hacker's perspective on AEM applications security

](<https://speakerdeck.com/0ang3el/a-hackers-perspective-on-aem-applications-security>)

[[[image: Avatar for Mikhail Egorov](#)] 0ang3el](<https://speakerdeck.com/0ang3el>)

0

4.1k

[

Securing AEM webapps by hacking them

](https://speakerdeck.com/0ang3el/securing-aem-webapps-by-hacking-them)

[[\[image: Avatar for Mikhail Egorov\]](#) 0ang3el](https://speakerdeck.com/0ang3el)

1

1.7k

[

AEM hacker approaching Adobe Experience Manager webapps in bug bounty programs

](https://speakerdeck.com/0ang3el/aem-hacker-approaching-adobe-experience-manager-webapps-in-bug-bounty-programs)

[[\[image: Avatar for Mikhail Egorov\]](#) 0ang3el](https://speakerdeck.com/0ang3el)

3

12k

[

Hunting for security bugs in AEM webapps

](https://speakerdeck.com/0ang3el/hunting-for-security-bugs-in-aem-webapps)

[[\[image: Avatar for Mikhail Egorov\]](#) 0ang3el](https://speakerdeck.com/0ang3el)

2

37k

[

Neat tricks to bypass CSRF-protection

](https://speakerdeck.com/0ang3el/neat-tricks-to-bypass-csrf-protection)

[[\[image: Avatar for Mikhail Egorov\]](#) 0ang3el](https://speakerdeck.com/0ang3el)

2

2.1k

[

CSRF-уязвимости все еще актуальны: как атакующие обходят CSRF-защиту в вашем веб-приложении

](https://speakerdeck.com/0ang3el/csrf-uiazvimosti-vsie-ieshchie-aktual-ny-kak-atakuiushchiie-obkhodiat-csrf-zashchitu-v-vashiem-vieb-prilozhienii)

[[\[image: Avatar for Mikhail Egorov\]](#) 0ang3el](https://speakerdeck.com/0ang3el)

1

600

Other Decks in Programming

[See All in Programming](#)

[

Japan Community Day at Kubecon + CloudNativeCon Japan 2026: Learning Container Privilege Control by Building My Own Low-Level Container Runtime

](<https://speakerdeck.com/ternbusty/cncj-container-runtime-privilege>)

[[\[image: Avatar for ternbusty\]](#) ternbusty](<https://speakerdeck.com/ternbusty>)

1

120

[

Augmenting AI with the Power of Jakarta EE

](<https://speakerdeck.com/ivargrimstad/augmenting-ai-with-the-power-of-jakarta-ee-8664ddb0-c49d-49b6-bb69-c20ffcccd8ad>)

[[\[image: Avatar for ivargrimstad\]](#) ivargrimstad](<https://speakerdeck.com/ivargrimstad>)

0

440

[

壊れたパーサから始める関数型設計と構成的なパーサ #fp_matsuri

](<https://speakerdeck.com/raiga0310/huai-retapasakarashi-meruguan-shu-xing-she-ji-togou-cheng-de-napasa>)

[[\[image: Avatar for ライガー\]](#) raiga0310](<https://speakerdeck.com/raiga0310>)

2

440

[

jsmini JavaScript Engine を作ってみた話

](https://speakerdeck.com/yosuke_furukawa/jsmini-javascript-engine-wozuo-tutemitahua)

[[\[image: Avatar for Yosuke Furukawa\]](#) yosuke_furukawa](https://speakerdeck.com/yosuke_furukawa)

PRO

0

290

[

ここ半年くらいでAIに作らせたR用ツール

](<https://speakerdeck.com/eitsupi/kokoban-nian-kuraideainizuo-rasetaryong-turu>)

[[\[image: Avatar for eitsupi\]](#) eitsupi](<https://speakerdeck.com/eitsupi>)

0

360

[

20260722_microCMSで考える、AI時代のコンテンツ運用設計

](<https://speakerdeck.com/yosh1/20260722-microcmsdekao-eru-aishi-dai-nokontentuyun-yong-she-ji>)

[[\[image: Avatar for Yoshihisa Kaino\]](#) yosh1](<https://speakerdeck.com/yosh1>)

0

270

[

【SRE NEXT 2026 Lunch Session】一人目専任SREの立ち上げを加速する — AIと進めたオンボーディングで2分を0.04秒にした話

](<https://speakerdeck.com/pkshadeck/sre-next-2026-lunch-session-ren-mu-zhuan-ren-srenoli-tishang-kewojia-su-suru-aitojin-metaonhoteinkute2fen-wo0-dot-04miao-nisitahua>)

[[\[image: Avatar for PKSHA Technology \(パークシャテクノロジー\)\]](#) pkshadeck]

(<https://speakerdeck.com/pkshadeck>)

PRO

0

3.4k

[

Laravelで学ぶ Webアプリケーションチューニング入門/web_application_tuning_101

](<https://speakerdeck.com/hanhan1978/web-application-tuning-101>)

[[\[image: Avatar for Ryo Tomidokoro\]](#) hanhan1978](<https://speakerdeck.com/hanhan1978>)

4

1.6k

[

PHP初心者セッション2026 ～生成AIでは見えない裏側を知る：今だからLAMPを通して仕組みを学ぶ～

](<https://speakerdeck.com/kashioka/phpchu-xin-zhe-setusiyon2026-sheng-cheng-aidehajian-enaili-ce-wozhi-ru-jin-dakaralampwotong-siteshi-zu-miwoxue-bu>)

[[\[image: Avatar for Hideo Kashioka\]](#) kashioka](<https://speakerdeck.com/kashioka>)

0

800

[

Claude Code全社展開のためにやったことn選～プラグイン302個・コミッター271人を支えるために～

](<https://speakerdeck.com/kenchan/claude-codequan-she-zhan-kai-notameniyatutakotonxuan-puraguin302ge-komituta271ren-wozhi-erutameni>)

[[\[image: Avatar for Kenichi Takahashi\]](#) kenchan](<https://speakerdeck.com/kenchan>)

1

340

[
アルゴリズムは何を圧縮しているのか — Haskell から育った「圧縮代数」というメンタルモデル
](<https://speakerdeck.com/naoya/compressed-algebra-with-haskell>)

[[\[image: Avatar for Naoya Ito\]](#) naoya](<https://speakerdeck.com/naoya>)

16

3.8k

[
複数の Claude Code が"放置"されてしまう問題をCLI ダッシュボードを自作して解決した話
](<https://speakerdeck.com/sumihiro3/fu-shu-no-claude-code-ka-fang-zhi-saretesimauwen-ti-wocli-tatusiyuhotowozi-zuo-sitejie-jue-sitahua>)

[[\[image: Avatar for sumihiro3\]](#) sumihiro3](<https://speakerdeck.com/sumihiro3>)

1

640

Featured

[See All Featured](#)

[
How to audit for AI Accessibility on your Front & Back End
](<https://speakerdeck.com/davetheseo/how-to-audit-for-ai-accessibility-on-your-front-and-back-end>)

[[\[image: Avatar for davetheseo\]](#) davetheseo](<https://speakerdeck.com/davetheseo>)

0

480

[
Color Theory Basics | Prateek | Gurzu
](<https://speakerdeck.com/gurzu/color-theory-basics-prateek-gurzu>)

[[\[image: Avatar for Gurzu\]](#) gurzu](<https://speakerdeck.com/gurzu>)

0

410

[
Exploring anti-patterns in Rails
](<https://speakerdeck.com/aemeredithe/exploring-anti-patterns-in-rails>)

[[\[image: Avatar for Elle Meredith\]](#) aemeredit](<https://speakerdeck.com/aemeredit>)

3

450

[

Dominate Local Search Results - an insider guide to GBP, reviews, and Local SEO

](<https://speakerdeck.com/greggifford/dominate-local-search-results-an-insider-guide-to-gbp-reviews-and-local-seo>)

[[\[image: Avatar for Greg Gifford\]](#) greggifford](<https://speakerdeck.com/greggifford>)

PRO

0

240

[

Learning to Love Humans: Emotional Interface Design

](<https://speakerdeck.com/aaron/learning-to-love-humans-emotional-interface-design>)

[[\[image: Avatar for Aaron Walter\]](#) aaron](<https://speakerdeck.com/aaron>)

275

41k

[

Taking LLMs out of the black box: A practical guide to human-in-the-loop distillation

](<https://speakerdeck.com/inesmontani/taking-llms-out-of-the-black-box-a-practical-guide-to-human-in-the-loop-distillation>)

[[\[image: Avatar for Ines Montani\]](#) inesmontani](<https://speakerdeck.com/inesmontani>)

PRO

3

2.3k

[

Building Applications with DynamoDB

](<https://speakerdeck.com/mza/building-applications-with-dynamodb>)

[[\[image: Avatar for Matt Wood\]](#) mza](<https://speakerdeck.com/mza>)

96

7.2k

[

The Psychology of Web Performance [Beyond Tellerrand 2023]

](<https://speakerdeck.com/tammyeverts/the-psychology-of-web-performance-beyond-tellerrand-2023>)

[[\[image: Avatar for Tammy Everts\]](#) tammyeverts](<https://speakerdeck.com/tammyeverts>)

49

3.5k

[

Making Projects Easy

](<https://speakerdeck.com/brettharned/making-projects-easy>)

[[\[image: Avatar for Brett Harned\]](#) brettharned](<https://speakerdeck.com/brettharned>)

120

6.7k

[

More Than Pixels: Becoming A User Experience Designer

](<https://speakerdeck.com/marktimemedia/more-than-pixels-becoming-a-user-experience-designer>)

[[\[image: Avatar for Michelle Schulp Hunt\]](#) marktimemedia](<https://speakerdeck.com/marktimemedia>)

3

480

[

Navigating the Design Leadership Dip - Product Design Week Design Leaders+ Conference 2024

](<https://speakerdeck.com/apolaine/navigating-the-design-leadership-dip-product-design-week-design-leaders-plus-conference-2024>)

[[\[image: Avatar for Andy Polaine\]](#) apolaine](<https://speakerdeck.com/apolaine>)

1

380

[

Distributed Sagas: A Protocol for Coordinating Microservices

](<https://speakerdeck.com/caitiem20/distributed-sagas-a-protocol-for-coordinating-microservices>)

[[\[image: Avatar for Caitie McCaffrey\]](#) caitiem20](<https://speakerdeck.com/caitiem20>)

333

23k

Transcript

-

What's wrong with w/ WebSocket API? Unveiling vulnerabilities in WebSocket

APIs Mikhail Egorov / @0ang3el #HACKTIVITY2019

whoami 2 • Security researcher / full-time bug hunter

▪ <https://bugcrowd.com/0ang3el> ▪ <https://hackerone.com/0ang3el> ▪ Conference speaker ▪ <https://www.slideshare.net/0ang3el> ▪ <https://speakerdeck.com/0ang3el>

Previous work 3 • https://media.blackhat.com/bh-us-12/Briefings/Shekyan/BH_US_12_Shekyan_Toukharian_Hacking_Websocket_Slides.pdf ▪ <https://www.nccgroup.trust/us/about-us/newsroom-and-events/blog/2017/may/wssip-a-websocket-manipulation-proxy/>

▪ <https://chybeta.github.io/2018/04/07/spring-messaging-Remote-Code-Execution-%E5%88%86%E6%9E%90-%E3%80%90CVE-2018-1270%E3%80%91/> ▪ <https://www.twistlock.com/labs-blog/demystifying-kubernetes-cve-2018-1002105-dead-simple-exploit/> ▪ <https://github.com/andresriancho/websocket-fuzzer> ▪ <https://www.irongeek.com/i.php?page=videos/derbycon9/stable-35-old-tools-new-tricks-hacking-websockets-michael-fowl-nick-defoe>

4 WebSocket protocol essentials

WebSocket protocol – RFC 6455 5 • Efficient two-way communication

protocol ▪ WebSocket is stateful (HTTP is stateless) ▪ Two main parts: handshake and data transfer

WebSocket protocol – RFC 6455 6 • Extensibility: subprotocols and

extensions ▪ Subprotocols ▪ <https://www.iana.org/assignments/websocket/websocket.xml#subprotocol-name> ▪ Wamp ▪ Stomp ▪ Soap ▪ ...

WebSocket protocol – RFC 6455 7 • Extensibility: subprotocols and

extensions ▪ Extensions ▪ <https://www.iana.org/assignments/websocket/websocket.xml#extension-name> ▪ permessage-deflate ▪ bbf-usb-protocol

WebSocket protocol – RFC 6455 8 • Origin-based security model

(Browser clients) ▪ No authentication ▪ Client must do client-to-server masking

WebSocket protocol support 9 ▪ Major web browsers ▪ Web

servers / Proxies ▪ Apache httpd, Nginx, IIS, ... ▪ HAProxy, Traefik, Varnish, Envoy, ... ▪ Cloud providers
▪ WebSocket API (api gateways) ▪ WebSocket proxying (load balancers)

-

WebSocket handshake 10 Upgrade request Base64(Random nonce) Protocol version Required

HTTP version

-

WebSocket handshake 11 Required status code BASE64(SHA1(Sec-WebSocket-Key || CONST))

-

WebSocket data transfer 12 \x00 – continuation frame \x01 –

text frame \x02 – binary frame \x08 – close frame \x09 – ping \x0A – pong other values are reserved

-

WebSocket data transfer - masking 13 ▪ Masking key is

32-bit long passed inside frame ▪ Client must send masked data ▪ $MASKED = MASK \wedge DATA$ (^ - XOR) ▪ Mechanism protects against cache poisoning and smuggling attacks

-

14 Cross-Site WebSocket Hijacking

-

WebSocket security for Web Browser 15 ▪ SOP doesn't work

for WebSocket in web browser ▪ Read from WebSocket cross-origin ▪ Write to WebSocket cross-origin ▪ Header Origin should be checked on handshake step (origin-based security model)

-

CSWSH 16 ▪ Cookies are used to authenticate upgrade request

▪ Header Origin isn't checked or checked poorly

-

CSWSH 17 ▪ CORS tricks from @albinowax are applicable to

WebSocket ▪ <https://portswigger.net/research/exploiting-cors-misconfigurations-for-bitcoins-and-bounties> ▪ Null origin ▪ Pre-domain wildcard ▪ Post-domain wildcard ▪ ...

-

CSWSH – Null origin 18 ▪ nullorigin.html <iframe src="data:text/html, <script>co nst

socket = new WebSocket('wss://example.com'); </script>"></iframe>

-

CSWSH 19 ▪ Playground ▪ <https://portswigger.net/web-security/websockets/cross-site-websocket-hijacking>

-

CSWSH – template for attack 5

-

Demo 5

-

22 Authentication / IDOR issues

-

Authentication 23 ▪ WebSocket protocol doesn't offer authentication ▪ Developers

have to roll out their own AuthN ▪ It's secure to check AuthN only during handshake ▪ Common secure implementations ▪ Session cookies ▪ Tokens

-

Broken authentication – Case 1 24 ▪ Some ID /

GUID is required in Upgrade request ▪ Guess ID ▪ Leak GUID (minor IDOR, ...)

-

Broken authentication – Case 2 25 ▪ No authentication during

handshake step ▪ Some ID / GUID required in API messages ▪ Guess ID ▪ Leak GUID (minor IDOR, ...)

-

Broken authentication – Case 2 26 ▪ Exposing GraphQL subscriptions

w/o AuthN ▪ <https://github.com/righettod/poc-graphql#subscriptions-websocket-endpoint-default-enabling> ▪ Path /subscriptions

-

Insecure Direct Object Reference issues 27 ▪ Strong authentication during

handshake step ▪ Some ID / GUID required in API messages ▪ Guess ID ▪ Leak GUID (minor IDOR, ...)

-

28 Smuggling through WebSocket

-

Reverse proxying WebSocket connection 29 Client Frontend Reverse proxy Backend

/socket.io/ Public WebSocket API

-

Reverse proxying WebSocket connection 30 Client Frontend Reverse proxy Upgrade

request Upgrade request Backend /socket.io/

-

Reverse proxying WebSocket connection 31 Client Frontend Reverse proxy Upgrade

request Upgrade request HTTP/1.1 101 HTTP/1.1 101 Backend /socket.io/

-

Reverse proxying WebSocket connection 32 Client Frontend Reverse proxy Upgrade

request Upgrade request HTTP/1.1 101 HTTP/1.1 101 WebSocket connection direct WebSocket connection Client - Backend Backend /socket.io/

-

Smuggling through WebSocket connection 33 Client Frontend Reverse proxy (vulnerable)

Private REST API Public WebSocket API Backend /internal /socket.io/

-

34 Backend Client Frontend Reverse proxy (vulnerable) /internal Upgrade request

/socket.io/ Sec-WebSocket-Version: 1337 Upgrade request Sec-WebSocket-Version: 1337 Version correctness isn't checked! Smuggling through WebSocket connection

-

35 Backend Client Frontend Reverse proxy (vulnerable) /internal Upgrade request

/socket.io/ Sec-WebSocket-Version: 1337 Upgrade request Sec-WebSocket-Version: 1337 HTTP/1.1 426 HTTP/1.1 426 Response correctness isn't checked! Smuggling through WebSocket connection

-

36 Backend Client Frontend Reverse proxy (vulnerable) /internal Upgrade request

/socket.io/ Sec-WebSocket-Version: 1337 Upgrade request Sec-WebSocket-Version: 1337 HTTP/1.1 426 HTTP/1.1 426 TLS connection direct TLS connection Client – Backend not WebSocket!!! Client can access /internal Smuggling through WebSocket connection

-

Challenge – challenge.0ang3el.tk 37 ▪ URL ▪ <https://challenge.0ang3el.tk/websocket.html> ▪ You

need to access flag on localhost:5000 ▪ Seems no one solved

-

Challenge – challenge.0ang3el.tk 38 ▪ Frontend ▪ Not disclosed WebSocket

reverse proxy ▪ socket.io.js ▪ Proxies only WebSocket API - /socket.io/ path ▪ Backend ▪ Flask, Flask-SocketIO, Flask-Restful ▪ Listens on localhost:5000 only

-

challenge1.py

-

challenge1.py - DEMO

-

Vulnerable reverse proxies 41 ▪ Vulnerable ▪ Varnish, Envoy proxy

<= 1.8.0, other non-disclosed ▪ Not vulnerable ▪ Nginx, HAProxy, Traefik, others

-

Varnish response 42 ▪ WebSocket proxying configuration ▪ <https://varnish-cache.org/docs/6.3/users-guide/vcl-example-websockets.html>

-

Smuggling through WebSocket connection 43 Client Frontend Reverse proxy (Nginx)

or another) Private REST API Public WebSocket API & REST API Backend /internal /api/socket.io/
/api/health

-

Smuggling through WebSocket connection 44 Client Frontend Reverse proxy (Nginx)

or another) Backend /internal /api/socket.io/ /api/health example.com GET HTTP/1.1 200

-

Smuggling through WebSocket connection 45 Client Frontend Reverse proxy (Nginx)

or another) Backend /internal /api/socket.io/ /api/health Only Upgrade: websocket header is checked!
POST /api/health?u= POST /api/health?u=

-

Smuggling through WebSocket connection 46 Client Frontend Reverse proxy (Nginx)

or another) Backend /internal /api/socket.io/ /api/health attacker.com GET HTTP/1.1 101 HTTP/1.1 101
HTTP/1.1 101 Only status code is checked for response! POST /api/health?u= POST /api/health?u=

-

Smuggling through WebSocket connection 47 Client Frontend Reverse proxy (Nginx)

or another) Backend /internal /api/socket.io/ /api/health HTTP/1.1 101 HTTP/1.1 101 TLS connection
direct TLS connection Client – Backend not WebSocket!!! Client can access /internal POST /api/health?
u= POST /api/health?u= Client-to-Server masking isn't checked by proxy!!!

-

Challenge2 – challenge2.0ang3el.tk 48 ▪ URL ▪ <https://challenge2.0ang3el.tk/websocket.html> ▪ You

need to access flag on localhost:5000 ▪ Seems no one solved

-

Challenge2 – challenge2.0ang3el.tk 49 ▪ Frontend ▪ Nginx as WebSocket

reverse proxy ▪ socket.io.js ▪ Proxies only /api/public path (socket.io and healthcheck) ▪ Backend ▪ Flask,
Flask-SocketIO, Flask-Restful ▪ Listens on localhost:5000 only

-

Challenge2 – challenge2.0ang3el.tk 50 ▪ Nginx config

-

Challenge2 – challenge2.0ang3el.tk 51 ▪ REST API - healthcheck

-

Challenge2.py 5

-

Challenge2.py - Demo 5

-

Vulnerable reverse proxies 54 ▪ Almost all proxies are affected

- But exploitation is limited ▪ External SSRF is required that returns status code ▪ ...

-

55 Discovering WebSocket APIs

-

Discovering WebSocket API 56 ▪ Monitor Upgrade requests ▪ Analyze

JavaScript files ▪ Try to establish WebSocket connection to each URL ▪ ...

-

57 Conclusion

-

Ideas for further research 58 ▪ Security of WebSocket subprotocols

- More smuggling techniques ▪ HTTP/2 and WebSocket ▪ ...

-

Thank you! @0ang3el